

# Provably Secure Four-Phase PUF-Based Authentication and Key Establishment for UAV Swarms

Md Ziyad Hussain      Rakesh Matam

Department of Computer Science and Engineering  
Indian Institute of Information Technology Guwahati, Assam, India

## Abstract

Unmanned Aerial Vehicle (UAV) swarms require authentication that is fast, lightweight, and resilient to the physical capture of individual drones. We present a four-phase authentication and key-establishment protocol whose root of trust is a Physical Unclonable Function (PUF) embedded in each UAV. The protocol (i) derives a *stable* per-device master key from the PUF through a fuzzy extractor with an exact min-entropy budget, so that no secret key is ever stored on the drone; (ii) authenticates the UAV and the Ground Station (GS) to one another with keyed message-authentication codes, keeping the raw PUF response entirely on-device; (iii) establishes GS-free, *per-pair* peer credentials delivered under authenticated encryption; and (iv) binds a mandatory, authenticated ephemeral Diffie–Hellman exchange into every session key to guarantee perfect forward secrecy. We prove six security theorems—mutual authentication in both directions, peer mutual authentication, replay/MITM resistance, physical-capture resistance, session-key secrecy, and perfect forward secrecy—each by a game-based reduction to standard assumptions, and we corroborate the authentication and secrecy claims with a symbolic model in the Tamarin prover. The design uses only a 160-bit hash (instantiable as SHA3-160 or SPONGENT-160), a keyed MAC, a lightweight AEAD, a key-derivation function, and a single elliptic curve, making it well suited to resource-constrained aerial platforms.

## 1. Introduction

Multi-UAV swarms coordinate continuously with a Ground Station over a command-and-control link and with one another over peer links to maintain formation, fuse sensor data, and relay traffic. Every such interaction presupposes *mutual authentication*: a UAV must verify the identity of its GS and of each peer before accepting commands, sharing telemetry, or forwarding messages. Public-key handshakes add latency and, more importantly, depend on private keys held in non-volatile memory (NVM) that a captured drone can surrender; pre-shared keys collapse the entire swarm once any single device is compromised.

Physical Unclonable Functions offer a different foundation. A PUF maps challenges to responses using nanometre-scale manufacturing variations unique to one integrated circuit [1]; it is unclonable, unpredictable, and tamper-evident, and it stores no key—the “key” is the silicon itself. Because PUF responses are noisy, a fuzzy extractor [2] reconciles a field response to its enrolment value and distills a reproducible key.

## Contributions.

- C1.** A four-phase protocol—secure enrolment, UAV–GS mutual authenticated key exchange, GS-free UAV–UAV peer authentication, and forward-secret session keying—built entirely from symmetric primitives plus one elliptic curve.
- C2.** A trust model in which each UAV holds *no* stored secret: a stable master key is regenerated on demand from the PUF and public helper data, with an explicit min-entropy budget (Theorem 2) governing parameter choice.
- C3.** Keyed authenticators throughout the handshake, so that the raw PUF response never appears on the wire and cannot be harvested (Theorems 3 and 4).
- C4.** Per-pair peer credentials distributed under authenticated encryption, confining the effect of a captured node to its own incident links (Theorem 7), together with a mandatory authenticated ephemeral exchange that delivers perfect forward secrecy (Theorem 9).
- C5.** A complete security analysis: six theorems with game-based reductions to standard assumptions, mirrored by a mechanised Tamarin model (Sections 6 and 7).

Section 2 fixes primitives and assumptions; Section 3 states the system and adversary model; Section 4 gives the design principles; Section 5 specifies the four phases; Sections 6 and 7 present the computational and symbolic analyses; Section 8 concludes.

## 2. Preliminaries and Cryptographic Primitives

Let  $\lambda$  denote the security parameter. A quantity is *negligible*,  $\text{negl}(\lambda)$ , if it decays faster than any inverse polynomial. We write  $x \xleftarrow{\$} S$  for uniform sampling,  $\parallel$  for concatenation (all concatenations are length-prefixed and uniquely parseable), and  $\oplus$  for bitwise XOR.

### 2.1 Hash function

$h : \{0, 1\}^* \rightarrow \{0, 1\}^{160}$  is a cryptographic hash instantiated in either of two interoperable modes—**SHA3-256 truncated to 160 bits** [6] or **SPONGENT-160** [5]—so that a software-optimised and a hardware-lightweight primitive share one interface. In the computational analysis  $h$  is modelled as a random oracle. Keyed functionality is provided by the dedicated constructions below rather than by bare  $h$ .

### 2.2 Keyed primitives

**Definition 1** (Message authentication code).  $\text{MAC} : \{0, 1\}^\lambda \times \{0, 1\}^* \rightarrow \{0, 1\}^\lambda$  is *existentially unforgeable under chosen-message attack* (EUF-CMA) if, for  $K \xleftarrow{\$} \{0, 1\}^\lambda$  and every probabilistic polynomial-time (PPT) adversary  $\mathcal{A}$ ,

$$\text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}) = \Pr[\mathcal{A} \text{ outputs a fresh valid } (m, \text{MAC}_K(m))] \leq \text{negl}(\lambda). \quad (1)$$

We instantiate MAC as HMAC over  $h$  (equivalently, a keyed duplex/sponge MAC).

**Definition 2** (Authenticated encryption). A nonce-based AEAD scheme  $\text{AE} = (\text{Enc}, \text{Dec})$  computes

$$c = \text{Enc}_K(\eta; \text{ad}; m), \quad m/\perp = \text{Dec}_K(\eta; \text{ad}; c), \quad (2)$$

and provides ciphertext indistinguishability (IND-CCA) and ciphertext integrity (INT-CTXT), with  $\text{Adv}_{\text{AE}}^{\text{ind}}, \text{Adv}_{\text{AE}}^{\text{int}} \leq \text{negl}(\lambda)$  for distinct nonces  $\eta$ . We use a lightweight nonce-based AEAD of the Ascon family [7], matching the resource profile of the platform.

**Definition 3** (Key-derivation function). KDF is HKDF (extract-then-expand) [3]. Each invocation carries a unique *domain-separation label*;  $\text{KDF}(k; \ell)$  denotes expansion of key material  $k$  under a label

$$\ell \in \{\text{"p2-auth"}, \text{"p2-sess"}, \text{"pair-cred"}, \text{"peer-auth"}, \text{"peer-sess"}\}. \quad (3)$$

We model  $\text{KDF}(\cdot; \ell)$  as an independent pseudorandom function (PRF) for each label, so that distinct labels yield independent keys.

### 2.3 Ephemeral key exchange

Let  $\mathbb{G}$  be the group underlying **X25519** [4] with generator  $g$ . Forward secrecy is reduced to the *gap computational Diffie–Hellman* (gap-CDH) assumption, equivalently the PRF-ODH assumption for KDF over  $\mathbb{G}$ .

### 2.4 PUF and fuzzy extractor

Each device  $i$  embeds a strong PUF  $\text{PUF}_i : \{0, 1\}^c \rightarrow \{0, 1\}^n$ . Two evaluations of the same challenge differ in at most  $t$  bits with overwhelming probability.

**Assumption 1** (PUF unpredictability). For a challenge  $C$  not previously queried, and given any polynomial set of challenge–response pairs of  $\text{PUF}_i$ , the response  $\text{PUF}_i(C)$  is computationally indistinguishable from uniform to a PPT adversary that does not physically possess device  $i$ .

**Assumption 2** (Tamper evidence). Invasive probing of device  $i$  destroys  $\text{PUF}_i$ ; its challenge–response behaviour can neither be extracted from captured silicon nor transferred to another device.

We employ a fuzzy extractor  $\text{FE} = (\text{Gen}, \text{Rep})$  formed from a code-offset secure sketch over a binary linear code  $\mathbf{C}$  with parameters  $(n, k, t)$  (instantiated as BCH(255, 131, 18), hence  $n - k = 124$  parity bits and correction radius  $t = 18$ ), composed with a strong extractor realised by KDF:

$$\text{Gen}(R) : \quad r \xleftarrow{\$} \{0, 1\}^k, \quad c = \mathbf{C}.\text{Encode}(r), \quad s = R \oplus c, \quad \text{seed} \xleftarrow{\$} \{0, 1\}^\lambda, \quad (4)$$

$$\text{mk} = \text{KDF}(\text{Ext}_{\text{seed}}(R); \text{"root"}), \quad P = (s, \text{seed}), \quad \textbf{return } (P, \text{mk}); \quad (5)$$

$$\text{Rep}(R', P) : \quad c' = R' \oplus s, \quad \hat{r} = \mathbf{C}.\text{Decode}(c'), \quad \hat{c} = \mathbf{C}.\text{Encode}(\hat{r}), \quad \hat{R} = \hat{c} \oplus s, \quad (6)$$

$$\textbf{return } \text{mk} = \text{KDF}(\text{Ext}_{\text{seed}}(\hat{R}); \text{"root"}). \quad (7)$$

**Lemma 1** (Reproduction correctness). *If the Hamming distance satisfies  $d_H(R, R') \leq t$ , then  $\text{Rep}(R', P)$  recovers  $\hat{R} = R$  and hence the identical master key  $\text{mk}$ .*

*Proof.*  $c' = R' \oplus s = c \oplus (R \oplus R')$  differs from the codeword  $c$  in  $d_H(R, R') \leq t$  positions, so bounded-distance decoding returns  $\hat{r} = r$ ; thus  $\hat{c} = c$  and  $\hat{R} = \hat{c} \oplus s = R$ . Both parties therefore apply  $\text{Ext}$  and  $\text{KDF}$  to the same value.  $\square$

Table 1: Notation.

| Symbol                                                                     | Meaning                                                 |
|----------------------------------------------------------------------------|---------------------------------------------------------|
| GS, UAV <sub><i>i</i></sub>                                                | ground station; the <i>i</i> -th UAV                    |
| TID <sub><i>i</i></sub>                                                    | rotatable temporary identity of UAV <sub><i>i</i></sub> |
| PUF <sub><i>i</i></sub> , <i>R</i> , <i>R'</i>                             | PUF of device <i>i</i> ; enrolment / field response     |
| FE = (Gen, Rep)                                                            | fuzzy extractor, Eqs. (5) and (7)                       |
| <i>P<sub>i</sub></i> = ( <i>s<sub>i</sub></i> , seed <sub><i>i</i></sub> ) | public helper data                                      |
| mk <sub><i>i</i></sub>                                                     | stable per-device master key (never stored on the UAV)  |
| mk <sub>GS</sub>                                                           | GS-only master key for pairwise credentials             |
| Cred <sub><i>ij</i></sub>                                                  | per-pair peer credential                                |
| <i>K<sub>auth</sub><sup>i</sup></i> , <i>K<sub>auth</sub><sup>ij</sup></i> | derived MAC keys                                        |
| SK <sub><i>i</i></sub> , SK <sub><i>ij</i></sub>                           | forward-secret session keys (Phase 2 / Phase 3)         |
| <i>N<sub>x</sub></i> , <i>T<sub>x</sub></i>                                | 128-bit nonce; timestamp                                |
| <i>a</i> , <i>b</i> ; <i>g<sup>a</sup></i> , <i>g<sup>ab</sup></i>         | ephemeral scalars; public shares; shared secret         |
| $\mathcal{T}$                                                              | session transcript (all preceding message fields)       |
| MAC, AE, KDF                                                               | keyed MAC; AEAD; key-derivation function                |

**Lemma 2** (Helper-data privacy). *Let  $\tilde{H}_\infty(R) = m$  be the conditional min-entropy of the enrolment response. The code-offset sketch *s* discloses at most  $n - k$  bits:*

$$\tilde{H}_\infty(R \mid P) \geq m - (n - k). \quad (8)$$

Consequently, if Ext is a  $(m - (n - k), \varepsilon)$ -strong extractor with  $\varepsilon = 2^{-\Omega(\lambda)}$  and output length  $\ell \leq m - (n - k) - 2 \log(1/\varepsilon)$ , then mk is within statistical distance  $\varepsilon$  of uniform given *P*.

*Proof.* Given the internal randomness *r*, *s* = *R* ⊕ *c* is a deterministic function of *R* taking values in a coset of  $\mathbb{C}$ ; revealing the coset of an  $[n, k]$  code fixes at most  $n - k$  syndrome bits, so by the chain rule for average min-entropy  $\tilde{H}_\infty(R \mid s) \geq \tilde{H}_\infty(R) - (n - k)$ , and seed is independent of *R*. The strong-extractor property applied to the residual source yields the claimed distance.  $\square$

**Remark 1** (Parameter selection). Because a code-offset sketch is a bounded-leakage primitive (Eq. (8)), the enrolment aggregates *L* independent response blocks  $R = (R^{(1)}, \dots, R^{(L)})$  chosen so that the residual entropy meets the key budget:

$$\sum_{b=1}^L (m_b - (n - k)) \geq \ell + 2 \log(1/\varepsilon), \quad \text{e.g. } \ell = 2\lambda, \quad (9)$$

where *m<sub>b</sub>* is the measured per-block min-entropy. This inequality determines *L* for a given PUF and target key length.

### 3. System and Adversary Model

The system comprises one trusted GS with tamper-resistant storage and *N* UAVs, each equipped with a PUF, a lightweight processor, and non-volatile memory. We consider a strong adversary

that combines Dolev–Yao network control [9] with physical capture and an active-challenger capability:

- **Network** ( $\mathcal{A}_{\text{net}}$ ). Reads, injects, modifies, reorders, replays, delays, and drops any message on any link.
- **Active challenger** ( $\mathcal{A}_{\text{chal}}$ ). May act as GS toward an honest UAV and submit adversarially chosen challenges and nonces.
- **Capture** ( $\mathcal{A}_{\text{cap}}$ ). May seize a device  $k$  and read its NVM contents  $\{\text{TID}_k, P_k, \{\text{Cred}_{kj}\}_j\}$  together with any live session keys. By Assumption 2 it obtains neither  $\text{PUF}_k$  nor the transient master key  $\text{mk}_k$  (which is never stored).
- **Post-session reveal**. For forward-secrecy analysis, the adversary may learn long-term secrets  $(\text{mk}_i, \text{Cred}_{ij})$  through a **Reveal** query issued only *after* the target session closes.

The adversary is PPT and, except with negligible probability, cannot invert  $h$ , forge MAC or AE, violate PUF unpredictability (Assumption 1), or solve gap-CDH. Physical side channels are out of scope; constant-time primitives are assumed.

## 4. Design Principles

The protocol rests on five principles that shape every phase.

- P1. Stable PUF-derived key, no stored secret.** Enrolment fixes a stable master key  $\text{mk}_i$  with the fuzzy extractor. The UAV regenerates  $\text{mk}_i$  on demand from its PUF and *public* helper data; no secret resides in NVM. Every authenticator is a MAC under a key derived from  $\text{mk}_i$ , which only the genuine device (through its PUF) and the GS (through its database) can compute.
- P2. The response stays on-device.** The fuzzy extractor executes entirely on the UAV; no PUF response, and no function of a response under an externally chosen mask, is ever transmitted.
- P3. Verify before acting.** A UAV validates the GS’s authenticator before performing any PUF-dependent computation or emitting any message, so a spurious challenger elicits no observable response.
- P4. Per-pair credentials under AEAD.** Peer trust uses per-pair credentials  $\text{Cred}_{ij}$  delivered confidentially and authentically under a PUF-derived session key, with domain-separated labels and per-message-type tags throughout.
- P5. Mandatory authenticated forward secrecy.** Every session key mixes in a fresh ephemeral Diffie–Hellman secret whose public shares are bound into the MAC transcript; there is no non-ephemeral derivation path.

## 5. The Four-Phase Protocol

### 5.1 Phase 1: Secure Enrolment

Enrolment is performed once per device over a secure out-of-band channel (Algorithm 1). The master key  $\text{mk}_i$  is the sole long-term secret and resides only in the GS’s tamper-resistant database; the UAV reconstructs it transiently whenever needed.

---

**Algorithm 1** Secure Enrolment of UAV<sub>i</sub>

---

**Input:** device UAV<sub>i</sub> with embedded PUF<sub>i</sub>; target key length  $\ell$

**Output:** GS record  $\langle \text{TID}_i, \mathbf{C}_i, P_i, \text{mk}_i \rangle$ ; UAV state  $\langle \text{TID}_i, \mathbf{C}_i, P_i \rangle$

- 1: GS selects a challenge block  $\mathbf{C}_i = (C_i^{(1)}, \dots, C_i^{(L)})$  and evaluates  $R \leftarrow \text{PUF}_i(\mathbf{C}_i)$  in situ
  - 2:  $(P_i, \text{mk}_i) \leftarrow \text{FE.Gen}(R)$   $\triangleright L$  chosen to satisfy the entropy budget (9)
  - 3: GS stores  $\langle \text{TID}_i, \mathbf{C}_i, P_i, \text{mk}_i \rangle$  in tamper-resistant memory
  - 4: UAV<sub>i</sub> stores  $\langle \text{TID}_i, \mathbf{C}_i, P_i \rangle$  only  $\triangleright P_i$  is public; no secret resides in NVM
- 

---

**Algorithm 2** Phase 2 — Mutual authentication and forward-secret keying

---

- 1: UAV<sub>i</sub>  $\rightarrow$  GS ( $M_1$ ): sample  $N_1, a$ ;  $\sigma_1 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M1"} \parallel \text{TID}_i \parallel N_1 \parallel T_1 \parallel g^a)$ ; send  $\langle \text{TID}_i, N_1, T_1, g^a, \sigma_1 \rangle$
  - 2: GS: reject if  $|T_{\text{now}} - T_1| > \Delta T$  or  $N_1$  already seen; fetch  $\text{mk}_i$ ; verify  $\sigma_1$
  - 3: GS  $\rightarrow$  UAV<sub>i</sub> ( $M_2$ ): sample  $N_2, b$ ;  $\sigma_2 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M2"} \parallel \text{TID}_i \parallel N_1 \parallel N_2 \parallel T_2 \parallel g^a \parallel g^b)$ ; send  $\langle N_2, T_2, g^b, \sigma_2 \rangle$
  - 4: UAV<sub>i</sub>: recompute  $\text{mk}_i \leftarrow \text{FE.Rep}(\text{PUF}_i(\mathbf{C}_i), P_i)$ ; verify  $\sigma_2$  before proceeding  $\triangleright$  a failed check aborts silently
  - 5: UAV<sub>i</sub>  $\rightarrow$  GS ( $M_3$ ):  $\sigma_3 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M3"} \parallel \mathcal{T})$ ; send  $\langle \sigma_3 \rangle$
  - 6: both set  $\text{SK}_i = \text{KDF}(\text{mk}_i \parallel g^{ab} \parallel \mathcal{T}; \text{"p2-sess"})$ ; GS rotates  $\text{TID}_i$
- 

## 5.2 Phase 2: UAV–GS Mutual Authenticated Key Exchange

Phase 2 (Algorithm 2) is a three-message mutual authenticated key exchange under  $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{"p2-auth"})$ , with ephemeral shares  $g^a$  (UAV) and  $g^b$  (GS) supplying forward secrecy.

**Remark 2.** No PUF response or masked response appears in any message;  $R$  is consumed locally by  $\text{FE.Rep}$  in (7), and the GS already holds  $\text{mk}_i$ . Because  $\text{mk}_i$  is reusable, a single enrolment supports arbitrarily many authentications; the challenge block  $\mathbf{C}_i$  serves only periodic key refresh, not per-session consumption.

## 5.3 Phase 3: UAV–UAV Peer Authentication

After Phase 2, the GS mints per-pair credentials and distributes them under authenticated encryption; peers then authenticate without further GS involvement (Algorithm 3).

**Remark 3.** Each message type carries a distinct tag ( $\text{"P1"}$ ,  $\text{"P2"}$ ,  $\text{"P3"}$ ) and a freshness element  $(n_i, n_j, T)$ , and the session key uses label  $\text{"peer-sess"}$  independently of the authenticator key  $K_{\text{auth}}^{ij}$  (label  $\text{"peer-auth"}$ ), so the key and the verifier are cryptographically separated.

## 5.4 Phase 4: Session Keys and Forward Secrecy

Phase 4 is the forward-secret keying embedded in Algorithms 2 and 3. Both session keys share the unified form

---

**Algorithm 3** Phase 3 — Per-pair credential issuance and peer handshake

---

- 1: **Issuance.** for peers  $i < j$ :  $\text{Cred}_{ij} = \text{KDF}(\text{mk}_{\text{GS}}; \text{"pair-cred"} \parallel i \parallel j)$ ;  $\text{GS} \rightarrow \text{UAV}_i$ :  
 $\text{AE.Enc}_{\text{SK}_i}(\eta; i \parallel j; \text{Cred}_{ij})$ , and symmetrically to  $\text{UAV}_j$
  - 2:  $\text{UAV}_i$ :  $\text{Cred}_{ij} \leftarrow \text{AE.Dec}_{\text{SK}_i}(\cdots)$ ; abort on  $\perp$   $\triangleright$  *confidential and authenticated*
  - 3: set  $K_{\text{auth}}^{ij} = \text{KDF}(\text{Cred}_{ij}; \text{"peer-auth"})$
  - 4:  $\text{UAV}_i \rightarrow \text{UAV}_j$  ( $P_1$ ): sample  $n_i, a'$ ;  $\tau_1 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P1"} \parallel i \parallel j \parallel n_i \parallel T \parallel g^{a'})$
  - 5:  $\text{UAV}_j \rightarrow \text{UAV}_i$  ( $P_2$ ): verify  $\tau_1$ ; sample  $n_j, b'$ ;  $\tau_2 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P2"} \parallel i \parallel j \parallel n_i \parallel n_j \parallel g^{a'} \parallel g^{b'})$
  - 6:  $\text{UAV}_i \rightarrow \text{UAV}_j$  ( $P_3$ ): verify  $\tau_2$ ;  $\tau_3 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P3"} \parallel T)$
  - 7: both set  $\text{SK}_{ij} = \text{KDF}(\text{Cred}_{ij} \parallel g^{a'b'} \parallel T; \text{"peer-sess"})$
- 

$$\text{SK} = \text{KDF}\left(\underbrace{k_{\text{lt}}}_{\text{mk}_i \text{ or } \text{Cred}_{ij}} \parallel g^{xy} \parallel T; \ell\right), \quad (10)$$

where the ephemeral public shares  $g^x, g^y$  are authenticated inside the MAC transcript. The exchange is mandatory: if the ephemeral component is absent, the session fails closed rather than deriving a non-forward-secret key.

## 6. Security Analysis

Throughout,  $q$  bounds the number of sessions/oracle queries, and reductions are tight up to the stated additive terms.

**Theorem 3** (Phase-2 mutual authentication). *Under Assumption 1, EUF-CMA security of MAC, and PRF security of KDF, Algorithm 2 achieves mutual entity authentication with injective agreement on the transcript  $\mathcal{T}$ . For every PPT  $\mathcal{A}$ ,*

$$\text{Adv}^{\text{p2-auth}}(\mathcal{A}) \leq 2 \text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}') + \text{Adv}_{\text{KDF}}^{\text{prf}}(\mathcal{A}'') + \frac{q^2}{2^{128}} + \text{negl}(\lambda). \quad (11)$$

*Proof.* Let  $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{"p2-auth"})$ . Game  $G_0$  is the real authentication experiment. Game  $G_1$  replaces  $K_{\text{auth}}^i$  by a uniform key; by PRF security of KDF and the near-uniformity of  $\text{mk}_i$  (Theorem 2, so  $\text{mk}_i$  is unknown to any  $\mathcal{A}$  lacking both the PUF and the database, by Assumption 1),  $|\Pr[G_1] - \Pr[G_0]| \leq \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{negl}$ .

(*GS authenticates UAV.*) A UAV is accepted only if  $\sigma_1$  verifies under  $K_{\text{auth}}^i$ ; producing a fresh valid  $\sigma_1$  without the key is an EUF-CMA forgery.

(*UAV authenticates GS.*) Symmetrically for  $\sigma_2$ : although every input to  $\sigma_2$  is public, the *key* is secret, so a fresh valid tag is again an EUF-CMA forgery.

A nonce collision that would allow transcript reuse occurs with probability at most  $q^2/2^{128}$ . Absent forgery and collision, both accepting parties share the identical  $\mathcal{T}$ , i.e. injective agreement holds. Summing the two forgery terms gives the bound.  $\square$

**Corollary 4** (No challenge read-out oracle). *An active  $\mathcal{A}_{\text{chal}}$  impersonating GS obtains no PUF response value; hence modelling attacks that require harvested challenge–response pairs are infeasible, under no assumption beyond Assumption 1.*

*Proof.* By step 4 of Algorithm 2, the UAV emits  $M_3$  only after  $\sigma_2$  verifies, which by Theorem 3 an adversary can force with probability at most  $\text{Adv}_{\text{MAC}}^{\text{euf}} + \text{negl}$ . When verification fails the UAV emits nothing; when it succeeds, the wire carries only  $\sigma_3$ , a MAC over public transcript fields—never a PUF response or a masked response. No challenge–response value is therefore exposed.  $\square$

**Theorem 5** (Phase-3 peer mutual authentication). *Under EUF-CMA security of MAC and INT-CTXT security of AE, Algorithm 3 achieves peer mutual authentication with injective agreement, without GS participation at handshake time and without exposing any per-pair secret in transit:*

$$\text{Adv}^{\text{p3-auth}}(\mathcal{A}) \leq 2 \text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}') + 2 \text{Adv}_{\text{AE}}^{\text{int}}(\mathcal{A}'') + \frac{q^2}{2^{128}} + \text{negl}. \quad (12)$$

*Proof. Issuance.*  $\text{Cred}_{ij}$  is delivered as  $\text{AE.Enc}_{\text{SK}_i}$ ; by INT-CTXT the adversary cannot make a UAV accept a different credential, and by IND-CCA it learns nothing about  $\text{Cred}_{ij}$  (used in Theorem 8). Since  $\text{SK}_i$  is a fresh, forward-secret key held only by  $\text{UAV}_i$  and the GS (Theorems 3 and 9), the adversary’s view is independent of  $\text{Cred}_{ij}$  except with probability  $\leq \text{Adv}_{\text{AE}}^{\text{int}}$  per endpoint.

*Handshake.* Given a secret  $\text{Cred}_{ij}$ , the tokens  $\tau_1, \tau_2, \tau_3$  are MACs under  $K_{\text{auth}}^{ij}$ ; each carries a distinct type tag and binds both identities and both nonces, so any fresh acceptance forces a matching sender computation—otherwise an EUF-CMA forgery. Because credentials are pair-specific, a third party holding some  $\text{Cred}_{k\ell}$  has no information about  $\text{Cred}_{ij}$  (independent KDF inputs) and cannot assert identity  $i$  to  $j$ . Nonce collisions contribute at most  $q^2/2^{128}$ .  $\square$

**Theorem 6** (Replay and MITM resistance). *Algorithms 2 and 3 resist replay and active man-in-the-middle attacks.*

*Proof.* Every accepted message is a MAC over a transcript that includes a fresh 128-bit nonce, a timestamp validated within  $\Delta T$ , a per-message type tag, and—from  $M_2/P_2$  onward—the peer’s nonce. A replay reuses a stale nonce or timestamp and is rejected by the freshness cache or window; a cross-session or cross-type substitution alters a MAC input and, by Theorems 3 and 5, cannot be re-authenticated without the key. Any active modification invalidates the covering MAC, and injective agreement on  $\mathcal{T}$  then guarantees both endpoints hold the identical view. The distinct type tags further prevent replaying a  $P_1$  token as a  $P_3$  token.  $\square$

**Theorem 7** (Physical-capture resistance). *Capture of  $\text{UAV}_k$  (reading its NVM) does not enable  $\mathcal{A}_{\text{cap}}$  to (i) impersonate any  $\text{UAV}_m$  ( $m \neq k$ ) to the GS in a fresh Phase 2, nor (ii) impersonate any peer pair  $(m, \ell)$  with  $k \notin \{m, \ell\}$  in Phase 3. A captured node’s peer-authentication exposure is exactly its  $N - 1$  incident links.*

*Proof.* The captured NVM holds  $\{\text{TID}_k, P_k, \{\text{Cred}_{kj}\}_j, \text{live SK}\}$ . (i) A fresh Phase 2 as  $\text{UAV}_m$  requires  $K_{\text{auth}}^m = \text{KDF}(\text{mk}_m; \cdot)$ ;  $\text{mk}_m$  is never stored (Algorithm 1) and, by Assumption 2, is not recoverable from device  $k$ ’s silicon, while Assumption 1 makes it unpredictable, so forgery reduces to EUF-CMA. (ii) Phase 3 for  $(m, \ell)$  requires  $\text{Cred}_{m\ell} = \text{KDF}(\text{mk}_{\text{GS}}; \cdot)$ ; the captured set  $\{\text{Cred}_{kj}\}$  is independent of  $\text{Cred}_{m\ell}$  whenever  $k \notin \{m, \ell\}$  (distinct KDF inputs;  $\text{mk}_{\text{GS}}$  never leaves the GS), so acceptance again reduces to EUF-CMA. Only pairs incident to  $k$  share a captured credential, giving the stated  $N - 1$  exposure.  $\square$

**Theorem 8** (Session-key secrecy). *For an adversary that corrupts no endpoint of the target session,  $\text{SK}_i$  (resp.  $\text{SK}_{ij}$ ) is indistinguishable from uniform:*

$$\text{Adv}^{\text{key-ind}}(\mathcal{A}) \leq \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{Adv}^{\text{gap-cdh}} + \text{negl}. \quad (13)$$

*Proof.* By (10) the key is  $\text{KDF}(k_{\text{lt}} \parallel g^{xy} \parallel \mathcal{T})$ . Two independent secrets protect it: the long-term key  $k_{\text{lt}}$  ( $\text{mk}_i$  by Theorem 2 and Assumption 1, or  $\text{Cred}_{ij}$  by IND-CCA of the AEAD delivery, Theorem 5) and the Diffie–Hellman secret  $g^{xy}$ . Modelling KDF as a PRF, replacing it by a random function costs  $\text{Adv}_{\text{KDF}}^{\text{prf}}$ ; the input  $g^{xy}$  is unpredictable under gap-CDH given only the authenticated shares  $g^x, g^y$  (Theorems 3 and 5). The output is therefore uniform up to the stated terms.  $\square$

**Theorem 9** (Perfect forward secrecy). *If the ephemeral scalars are erased after use, then revealing the long-term secrets ( $\text{mk}_i$ ,  $\text{Cred}_{ij}$ , or even  $\text{mk}_{\text{GS}}$ ) after a target session closes does not compromise that session’s key:*

$$\text{Adv}^{\text{pfs}}(\mathcal{A}) \leq \text{Adv}^{\text{gap-cdh}} + \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{negl}. \quad (14)$$

*Proof.* A post-session Reveal yields  $k_{\text{lt}}$  but not the erased  $x, y$ . The key (10) still depends on  $g^{xy}$ , which the adversary must compute from the transcript shares  $g^x, g^y$ —a gap-CDH instance, since those shares were authenticated (no substitution, by Theorems 3 and 5) and the scalars are gone. Reducing KDF to a PRF on the now-unknown input yields indistinguishability up to the stated terms. Because the ephemeral exchange is mandatory and fail-closed (Section 5.4), no non-forward-secret key exists to attack.  $\square$

## 7. Symbolic Verification

We corroborate the authentication and secrecy results with a symbolic model in the Tamarin prover [10], whose multiset-rewriting calculus natively expresses freshness, stateful credential issuance, and compromise (“reveal”) events.

**Model.** The symbols  $h$ , MAC, AE, KDF are functions with the usual equational theory

$$\text{AE.Dec}_k(\eta; ad; \text{AE.Enc}_k(\eta; ad; m)) = m. \quad (15)$$

Each PUF is a private per-device function  $\text{puf}(\sim \text{seed}_i, c)$ ; helper data and all wire terms are public. The GS database and issued credentials are linear facts. Fresh values  $(\sim N, \sim a)$  model nonces and ephemeral scalars;  $g^{ab}$  uses the built-in Diffie–Hellman theory.

**Trust and compromise rules.** The Dolev–Yao adversary controls the network. Two additional rules model the strong adversary: **Reveal\_NVM**( $k$ ) emits  $\text{TID}_k, P_k, \{\text{Cred}_{kj}\}$  but neither  $\text{puf}_k$  nor  $\text{mk}_k$ ; **Reveal\_LT** emits  $\text{mk}_i$  or  $\text{Cred}_{ij}$  with an action timestamp used to restrict forward-secrecy queries to post-session reveals.

**Verification lemmas.** The following lemmas are discharged by `tamarin-prover --prove` and correspond one-to-one with Theorems 3 and 5 to 9.

```
lemma p2_injective_agreement:
  "All U GS t #i. Commit(U,GS,<'p2',t>@i
    ==> (Ex #j. Running(GS,U,<'p2',t>@j & j<i)
      & not (Ex U2 GS2 #i2. Commit(U2,GS2,<'p2',t>@i2 & not #i2=#i))"

lemma p3_injective_agreement:
  "All i j t #x. Commit(i,j,<'p3',t>@x
```

```

==> (Ex #y. Running(j,i,<'p3',t>@y & y<x)"

lemma no_replay:
  "All t #a #b. Accept(t)@a & Accept(t)@b ==> #a=#b"

lemma capture_isolation:
  "All m l #x. PeerKey(m,l)@x
    & (Ex k #r. RevealNVM(k)@r & not k=m & not k=l)
    ==> not (Ex #e. K(SKpair(m,l))@e)"

lemma key_secretcy:
  "All k #x. SessionKey(k)@x & not (Ex #r. RevealEndpoint()@r)
    ==> not (Ex #e. K(k)@e)"

lemma forward_secretcy:
  "All k #x. SessionKey(k)@x
    & (All #r. RevealLT()@r ==> x<r)
    ==> not (Ex #e. K(k)@e)"

```

**Modelling scope.** The symbolic layer treats the PUF as a noiseless private function—error tolerance is a computational correctness property (Theorem 1) outside the symbolic theory—and abstracts confidential delivery with a symmetric-encryption operator, leaving the fine-grained confidentiality argument to the computational analysis (Theorem 8). As a self-consistency check, a rule that delivered a credential in the clear falsifies **key\_secretcy**, confirming that the AEAD wrapping is load-bearing in the model.

## 8. Conclusion

We presented a four-phase PUF-based authentication and key-establishment protocol for UAV swarms. The design roots all authentication in a stable, PUF-derived master key that is regenerated on demand and never stored, keeps the raw PUF response entirely on-device, protects peer authentication with per-pair credentials delivered under authenticated encryption, and makes an authenticated ephemeral Diffie–Hellman exchange a mandatory component of every session key. A helper-data privacy lemma with an explicit min-entropy budget governs parameter selection. Six theorems, each proved by reduction to standard assumptions and mirrored by a mechanised Tamarin model, establish mutual authentication in both directions, peer authentication, replay and MITM resistance, physical-capture resistance, session-key secrecy, and perfect forward secrecy. Built from a 160-bit hash, a keyed MAC, a lightweight AEAD, a KDF, and a single elliptic curve, the protocol is well matched to the resource constraints of aerial platforms.

## References

- [1] G. E. Suh and S. Devadas, “Physical unclonable functions for device authentication and secret key generation,” in *Proc. 44th ACM/IEEE Design Automation Conf. (DAC)*, 2007, pp. 9–14.

- [2] Y. Dodis, R. Ostrovsky, L. Reyzin, and A. Smith, “Fuzzy extractors: How to generate strong keys from biometrics and other noisy data,” *SIAM J. Comput.*, vol. 38, no. 1, pp. 97–139, 2008.
- [3] H. Krawczyk, “Cryptographic extraction and key derivation: The HKDF scheme,” in *Advances in Cryptology — CRYPTO*, 2010, pp. 631–648.
- [4] D. J. Bernstein, “Curve25519: New Diffie–Hellman speed records,” in *Public Key Cryptography — PKC*, 2006, pp. 207–228.
- [5] A. Bogdanov, M. Knežević, G. Leander, D. Toz, K. Varıcı, and I. Verbauwhede, “SPONGENT: A lightweight hash function,” in *Cryptographic Hardware and Embedded Systems — CHES*, 2011, pp. 312–325.
- [6] National Institute of Standards and Technology, “SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions,” FIPS PUB 202, 2015.
- [7] C. Dobraunig, M. Eichlseder, F. Mendel, and M. Schläffer, “Ascon v1.2: Lightweight authenticated encryption and hashing,” *J. Cryptology*, vol. 34, no. 3, 2021.
- [8] M. Bellare and P. Rogaway, “Entity authentication and key distribution,” in *Advances in Cryptology — CRYPTO*, 1993, pp. 232–249.
- [9] D. Dolev and A. C. Yao, “On the security of public key protocols,” *IEEE Trans. Inf. Theory*, vol. 29, no. 2, pp. 198–208, 1983.
- [10] S. Meier, B. Schmidt, C. Cremers, and D. Basin, “The TAMARIN prover for the symbolic analysis of security protocols,” in *Computer Aided Verification — CAV*, 2013, pp. 696–701.